

Introduction to Burp Suite

7BUIS022W

Dr Ayman El Hajjar

Week 2

Lab Requirements

- If you working on your own machine:
 - You need to use **BurpSuite community edition**
 - You need to have OWASP Juice Box Running on Kali Linux machine
 - For the assessment: You need to setup the assignment scenario on Kali Linux machine
- If you working on a CLG.43 or CLG.45 machine:
 - You should use the Pre-Installed **BurpSuite professional edition**.
 - If you are working on your assignment, you need to setup the assignment scenario on Kali Linux machine

Lab Objectives

1. Obtain BurpSuite
2. Academy account on BurpSuite
3. Understand the basics of BurpSuite.
4. Intercepting HTTP traffic
5. Understand DREAD Threat modelling
6. Understand weekly labs structure

1 Obtain BurpSuite

- Depending where you are, you will be able to use BurpSuite.
- BurpSuite comes in different editions.

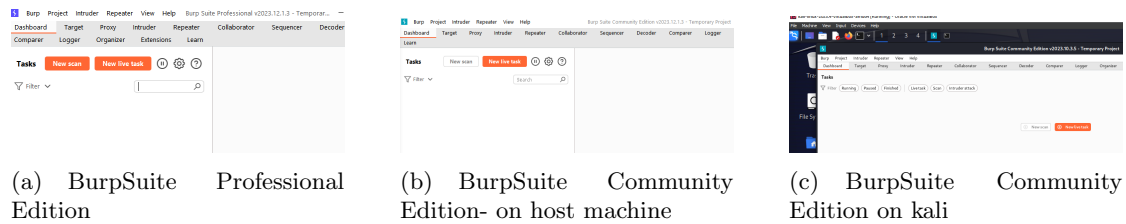


Figure 1: Overall caption for the three images

- you can read about the different editions and how they are installed in the labs on the school wiki, the Burpsuite page

1. BurpSuite professional edition

- Installed on the university machines in Labs CLG.43 and CLG.45 on both Windows and Linux images.
- Has more features than the community edition.
- It is installed on both Linux and Windows images of the CLG.43/45 labs.
- Available for use at any times

2. BurpSuite community edition

- On Kali Virtual machine
 - * Pre-Installed.
 - * To start it, open a terminal and type **burpsuite**
- On your host machine
 - * You can also install BurpSuite community edition on your machine directly.
 - * To download it, click on the BurpSuite download link
 - * Make sure you download the software for the right platform

2 Academy account on BurpSuite

- In this module we will be working through the BurpSuite Academy tutorials and labs and apply everything we learn on the OWASP VM machine and on the Assessment scenario.
- First, please create an account on BurpSuite on the Web Security Academy page
- On the Web Security Academy learning Paths, there are three main categories of topics. They are Server Side Vulnerabilities, Client-side Vulnerabilities, & Advanced Topics. We will not cover all the labs in those topics due to the limited time to have on the module. However, you are free to explore them and improve your learning on your own time.

- You can see all the topics on the All topics page on the Web Security Academy site
- Each topic contains an explanation of what the vulnerability is and there will be several labs you can practice to improve your learning on the topic
- It is advisable that you work in parallel with the lectures and the activities we conduct in the lab to help with your learning and understanding of the topic

3 BurpSuite. The basics

- For today, and assuming you have BurpSuite ready in front of you and a web Security account , we can start by Understanding the interface and the basics of the software.
- One way to get yourself familiar with BurpSuite works and its interface, is to look at the learn tab from within BurpSuite software as shown in Fig.2

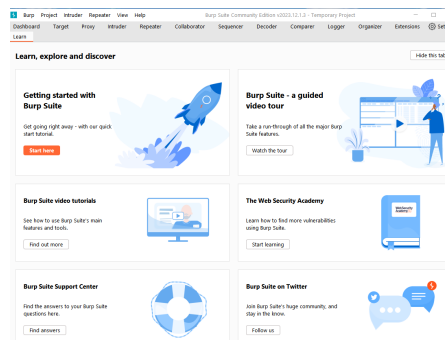


Figure 2: Learn tab on BurpSuite

- You should start by looking at the BurpSuite User Interface guide video.
- In summary, the interface tabs show different tools. Below you can find a summary from Burp Suite tools Documentation:
 - **Dashboard** - The Dashboard tab provides a central location for monitoring and controlling all of the automated tasks in your project, such as vulnerability scans or live tasks.
 - **Target** - This tool contains detailed information about your target applications, and lets you drive the process of testing for vulnerabilities.
 - **Burp's browser** - This browser is preconfigured to work with the full functionality of Burp Suite right out of the box.
 - **Proxy** - This is an intercepting web proxy that operates as a man-in-the-middle between the end browser and the target web application. It lets you intercept, inspect and modify the raw traffic passing in both directions.

- **Scanner Professional** (only in BurpSuite professional) - This is an advanced web vulnerability scanner, which can automatically crawl content and audit for numerous types of vulnerabilities.
- **Intruder** - This is a powerful tool for carrying out automated customized attacks against web applications. It is highly configurable and can be used to perform a wide range of tasks to make your testing faster and more effective.
- **Repeater** - This is a tool for manually manipulating and resending individual messages, and analyzing the application's responses.
- **Sequencer** - This is a sophisticated tool for analysing the quality of randomness in an application's session tokens or other important data items that are intended to be unpredictable.
- **Decoder** - This is a useful tool for performing manual or automated decoding and encoding of application data.
- **Comparer** - This is a handy utility for performing a visual "diff" between any two items of data, such as pairs of similar HTTP messages.
- **Logger** - This is a tool for recording and analysing HTTP traffic that Burp Suite generates.
- **Inspector** - This provides some useful features for analysing and editing HTTP and WebSockets messages.
- **Collaborator Professional** (only in BurpSuite professional) - This is a manual tool for identifying out-of-band vulnerabilities.
- **DOM Invader** - This is a tool for finding DOM XSS vulnerabilities.
- **Clickbandit** - This is a tool for generating Clickjacking attacks.
- **Message editor** - This is a tool for viewing and editing HTTP requests and responses throughout Burp.
- **Engagement tools Professional** - Configure various engagement-related tasks.
- **Search** - This is a tool for performing searches in Burp Suite.
- **Infiltrator** - This is a tool for detecting whether Burp's input is passed to potentially unsafe APIs.
- **Organizer** - This is a tool for storing and annotating HTTP messages that you want to investigate later.

- **Brief summary** of the learning and understanding will be provided.

4 Intercepting HTTP traffic (Requests and Responses)

- First watch the video on how to intercept HTTP traffic with the Burp Suite proxy before you move to doing this on OWASP.

- Note In this video, we are using the BurpSuite proxy. This means that there are no need to setup our own proxy since the burpsuite proxy is already preset on the Chromium browser. You can see it in the proxy tab of BurpSuite when you click on Open Browser.
- Visit the Buprsuite academy site for this activity and complete the activity.
- You can also do this on OWASP VM. make sure OWASP is running.
- Take note of what you were able to capture simply by browsing the OWASP VM.
- Did you find anything interesting or anything that can give you any clues?
- **In your own time, start by completing this activity on your assignment activity and see what you can find.**

5 Modifying HTTP traffic

- Now, in BurpSuite, you can not only intercept traffic before it reaches the server, but you can also modify the response before it is sent to the server.
- Watch the video on how to modify the HTTP requests with the Burp Suite proxy before you move to doing this on OWASP.
- Before you move on, make sure you have already created the BurpSuite academy account in section 2
- Visit the Buprsuite academy site for Modifying HTTP requests activity and complete it.
- Now you have completed this activity on the BurpSuite academy, let's fire up the OWASP VM and modify some HTTP traffic.
- This is an example however you can do more if you browse around OWASP.
- While OWASP is running on 192.168.56.111
 1. Open BurpSuite (community or professional for this activity won't make any difference)
 2. click on Proxy and make sure the **Intercept is OFF**
 3. On Chromium, point the browser to 192.168.56.111
 4. Select "Damn Vulnerable Web Application"
 5. You will be presented with a login page. Before you move further
 6. Turn the **Interpect to On** by clicking on Intercept is OFF to toggle to ON (Change it to on)
 7. Now try to login with username "test" and password "test"

8. Click login
 9. Go back to Burpsuite, look for the parameters username and password
 10. change them to username "admin" and password "admin"
 11. Click on Forward on BurpSuite. You will find that you have logged in with Admin user privileges.
 12. Try to browse around the OWASP VM for now and see if you can modify any other requests
- **In your own time, start by completing this activity on your assignment activity and see what you can find.**

6 Setting the Target scope

- Now, in BurpSuite, the messages you are intercepting can be from many different sources and websites, however your scope for a particular penetration test for example is a specific website. You can set the target scope, so that BurpSuite ignores HTTP traffic from other sites.
- Visit the Burpsuite academy site for the Setting the target scope activity and follow it
 - Note: I said follow it, you will not be able to complete the steps. We were simply learning how to set the target scope so the objective is not really to solve the "Information disclosure in error messages" lab activity.,
- Try to define the scope on BurpSuite for OWASP VM.
- **In your own time, start by completing this activity on your assignment activity and see what you can find.**

7 Reissue requests with Burp Repeater

- An important tool in BurpSuite, is the repeater tool. Let's see how it works.
- Visit the Burpsuite academy site for Reissue requests with Burp Repeater activity and follow it
- Let's see if we can find anything interesting on the OWASP VM and see how we can manipulate the HTTP requests with different parameters.
- on Chromium (proxy browser for BurpSuite), Visit the BodgeIt Shop and explore the different products. See if you can find how many products there are by using the Repeater function

- Note that the server is responding differently to how the BurpSuite activity example responded. Look at the response.
- on Chromium (proxy browser for BurpSuite), Now Visit the Joomla Shop and explore the different products. See if you can find how many products there are by using the Repeater function. Try to also visit the gallery and see how many images are in the gallery
 - Note that the server is responding differently to how the BurpSuite activity example responded. Look at the response.
- **In your own time, start by completing this activity on your assignment activity and see what you can find.**

8 Run your first scan

- An important tool in BurpSuite, is the BurpScanner.
- **Burp Scanner is only available in Burp Suite Professional and Burp Suite Enterprise Edition. If you're using Burp Suite Community Edition, then you won't be able to follow this tutorial.**
- Make sure you clear your filter and remove any target scope.
- Visit the Burpsuite academy site to run your first scan and follow the activity
- After you complete the activity, try to scan the OWASP VM. Try the different scan configuration settings and observe what each provide. (Not this might take some time)
- **In your own time, start by completing this activity on your assignment activity and see what you can find.**

9 Generate a report

- Have a look at how to generate a report from all your findings on the Generate reports activity page.
- For your assignment, this is the something that you will have to complete for the scenario you are conducting the penetration test on.

10 Understand DREAD Threat modelling

- DREAD stands for all the components that needs to be assessed in a vulnerability. The components are:
 - **D for Damage:** How big would the damage be if the attack succeeded?

- **R for Reproducibility:** How easy is it to reproduce an attack?
- **E for Exploitability:** How much time, effort, and expertise is needed to exploit the threat?
- **A for Affected Users:** If a threat were exploited, what percentage of users would be affected?
- **D for Discoverability:** How easy is it for an attacker to discover this threat?
- The calculation is done as following
 - For each of the components of DREAD, a value is given, from low severity (0) to High Severity (10)
 - The overall DREAD is the addition of all the values of the five components and divided by 5.
- You can read about this model on these links [DREAD threat modelling technique](#) and [OWASP threat modelling process](#) .
- DREAD was first used by Microsoft. Microsoft has used to another Secure Development Lifecycle called SDL.
- Although DREAD is not used as much as it used to be, it is still a viable method to use to at least allow security analysts to prioritise what they need to deal with. Some sees it as a subjective model, in a way that the cyber security analyst needs to quantify the value of each of the components of DREAD depending on how he/she sees the severity of it.
 - For each vulnerability you identify in your assignment, you are expect to provide an **Overall DREAD score with a brief justification for each of the points..**

11 Understand weekly labs structure

- For each lab, you are required to complete three tasks:
 1. **Before the class** - Complete the learning requirements from BurpSuite academy
 2. **In tutorial sessions** - Use OWASP VM and conduct the assessment on the specific lab topic vulnerability
 3. **In your own time** -Conduct your assessment using Juice box environment
 - For example for this week lab, see the checklist below of activities you are expected to complete
- ☐ **Before the class**
- ☐ Have a working BurpSuite application on my own machine

- ☐ Watch "Video for the Guided tour"
- ☐ Video for "How to intercept traffic"
- ☐ **In tutorial sessions**
 - ☐ Conduct simple assessment on OWASP machine
- ☐ **In your own time**
 - ☐ Conduct simple assessment on the Juice Shop site